

T1 - Tutorial: Exposed attack surface

WARNING: probing a host that does not belong to you by means of port scanning is considered an offensive procedure; moreover, in some countries, it can be an **illegal activity**. Be aware of what you are doing and carefully consider the possible consequences. The operations reported in this document must be only considered in terms of **educational activity** and for **defensive purposes**.

PREREQUISITES:

- Networking: [subnet](#).
- Networking, basic knowledge of the [ICMP](#) protocol. to send error messages (e.g. 'destination unreachable') and operational information regarding network management (diagnostic)
- Networking, basic knowledge of the [TCP](#) transport protocol. In particular, the three-way handshake implemented by TCP to start new connections (i.e., "connection establishment").
- Networking, basic knowledge of the [UDP](#) transport protocol.

Outline

Idea: try to mimic the behaviour of the attacker that got the access to a Network (example: compromise the University Network)

1. **Phase I: Reconnaissance & Discovery** (tools: nmap, netdiscover)
2. **Phase II: Service Enumeration** (tool: nmap)
3. **Phase III: Vulnerability Assessment** (tools: nmap scripts, nikto)
4. **Phase IV: Post-Exploitation & Hardening** (tools: lynis)

Discover what there is around (check other system connected to the network). After service discovery that can interest the attacker, he decided if it is a good idea to do a lateral movement from his entry point to other nodes that are inside the network (to doing this, he will exploit vulnerabilities)

Trying to understand the specific software that is running in system that the attacker is targeting

Spotting existing vulnerabilities in the software (typically, they use a vulnerability that is known, not a new one or a 0-day; so this task can be automated)

When it is possible to move from one node to another within the network (lateral movement), but the attacker has not yet fully compromised the nodes (i.e. has not taken control of them as an administrator): this phase therefore involves privilege escalation (because he wants to stay as much as possible in the system to control it)

Exposed attack surface

Every host that is connected to a network has an **exposed attack surface**. Even if there are no active services that are accepting requests from the network, there is always a protocol stack (typically implemented in the OS kernel) that performs many complex operations on the inbound packets that are received from the network. Very often, an online host also provides services that can be accessed from the network (typically not only from the local area network but also from the Internet). Being able to precisely determine the exposed attack surface of the devices in our organization is a basic network security procedure.

Anche se non ci sono servizi attivi, il protocol stack deve eseguire operazioni complesse su ogni pacchetto in entrata: Analisi dei dati: Deve leggere l'intestazione del pacchetto per capire se è destinato a lui.

Gestione degli errori: Deve gestire protocolli di controllo come l'ICMP (usato per i messaggi di errore o i "ping"). Assemblaggio: Se un file grande viene diviso in tanti piccoli pacchetti, il kernel deve rimetterli insieme.

Core point in Cybersecurity: understanding the problem, solutions are complex and they depend from your specific setup and threat model

nmap has a modular structure: you can add modules created by community to spot new vulnerabilities other than the ones spotted by the standard version of nmap (adding these modules can be very dangerous if the modules added have trojan)

1A Network Mapper (network discovery)

The network mapper (nmap) is an open-source tool that has been specifically designed for discovering the host/devices that are connected to a specific network and to probe their exposed attack surface. (identify the nodes that are connected to the network and try to classify them)

(only checking around what is available on our network)

We start considering the network discovery procedure only. We assume that our host is connected to a specific network and we are going to discover what hosts are in the same network. For example, we will consider the subnet: 192.168.0.0/24.

`sudo nmap -sn -v 192.168.0.0/24`

An attacker will carry out this action whilst trying to remain as untraceable as possible (keeping the duration of the process as short as possible and minimising the amount of data exchanged)

In this case, we instructed nmap to perform a discovery that is (mainly) based on the Internet Control Message Protocol (ICMP). It is necessary to briefly consider also the security of the procedure described above for who is running nmap. In fact, nmap in this case requires to be run with root privileges and it will parse data that is obtained from the network (i.e., the responses of the different hosts that are probed). **This can be a security issue that needs to be properly mitigated. How?**

If in nmap there is malicious code/trojan and i execute it with admin privileges, the computer is compromised (for example, can install a keylogger in the computer, if nmap is compromised). In this case, running nmap will mean exposing all the data that is in the home directory. When we download nmap, we trust the source of installation

It is also possible to perform the discovery using other protocols. Some hosts will likely respond to a specific protocol but not to another. It is also worth noting that if a host remains silent to every packet that it receives then we will be unable to discover it.

`sudo nmap -sS -v 192.168.0.0/24`

Now, the discovery has been executed using TCP-SYN packets. Why do many attackers prefer to perform ICMP scans instead of running TCP or UDP probes?

How? If i don't trust nmap, i can use it using a one-time Virtual Machine that i throw away every time that i use nmap

of the TCP three-way handshake

1B netdiscover (active and passive network discovery)

Many tools have been implemented for executing a network discovery. netdiscover is another relevant one.

`> sudo netdiscover -i <network_device> -p`

In this case, the network discovery procedure is **passive**. This means that we are **not probing** the target devices sending packets on the network but only listening on the network. Since many protocols are based on broadcasts (e.g., DHCP) then it is possible to discover other devices running in our LAN. That's nice for an attacker but it can also be useful for defenders (i.e., mitigation based on network monitoring).

for mitigation of active attacks

The service name is guessed by only means of the port number (so it isn't certain). So, i need to go in deep to be certain

Attackers often prefer TCP-SYN scans to ICMP scans for reasons of accuracy and stealth, although ICMP has its advantages in terms of speed and simplicity. This is why an attacker might choose one protocol over another for the discovery phase:

1. Reliability and "Visibility" of Hosts: Many modern firewalls or operating systems are configured to ignore ICMP packets for security reasons. If a host does not respond to ICMP, it will remain invisible. A TCP-SYN scan sends a connection-initiation packet; if the port is open, the host must respond by protocol, revealing its presence even if it 'hides' the ICMP.
2. Noise and Detection: ICMP scans are very fast for mapping large networks, but they are easily traceable by network monitoring systems. TCP-SYN is considered more stealthy. nmap sends a SYN packet, receives the SYN-ACK from the host, and then immediately terminates the connection without completing the three-way handshake. Since the connection is never fully established, many older logging systems did not even record the connection attempt.
3. Why choose ICMP in some cases? Despite its limitations, ICMP is chosen because it is much quicker to scan an entire subnet with ICMP than to test thousands of TCP ports, and in many corporate or university local area networks (LANs), ICMP is not filtered internally, making discovery immediate

Active Attack: getting information quickly, but with more probability of being spotted.
Passive Attack: will get less information (so, i need more time to get information), but with 0 probability of being spotted

Typically, stay in passive attack for weeks/months to get information and then, after this procedure, start with active attack

2 Network Mapper (port scanning)

After finding one or more hosts to which we are interested for a deeper analysis, we can revert to nmap for performing a port scanning of such devices. Now, we are interested in finding what services (i.e., running processes) are listening to network sockets and are accessible from outside the specific host.

We start by using an interesting feature of nmap that is often able to determine what OS (and version) is running on the chosen device.

`sudo nmap -O <ip_host_address>`

to identify the operating system (OS Detection) of the specified host. -O: Enables operating system detection. Nmap sends a series of TCP and UDP packets to various ports and analyses the responses (the 'fingerprint'). It then compares the results with an internal database containing thousands of known OS profiles.

It is worth noting that nmap has already been able to spot some open ports on that device (i.e., services that are exposed to the network). More complex scanning procedures can be triggered.

`sudo nmap -sT <ip_host_address>`

Performs a TCP connect scan. Unlike a SYN scan, this completes the TCP three-way handshake to check whether a port is open.

Host scanning using the TCP protocol.

`sudo nmap -sU <ip_host_address>`

Host scanning using the UDP protocol.

By default, nmap scans a small subset of ports, namely the 1,000 most common ports (unless the -p option is specified).

To speed up the operations, nmap typically scans only a small subset (i.e., 1000) of all the available network ports. These are ports where typically there are running services. It is possible to force nmap to scan all the existing ports at the cost of some extra execution time.

`> sudo nmap -sT -p0-65535 <ip_host_address>`

range delle porte da scansionare (in questo caso, sono in totale 2^{16} perché 16 bit per numerare le porte)

For different reasons, performing a full scan based on UDP is going to be very slow:

`> sudo nmap -sU -p0-65535 <ip_host_address> -v`

-v: attiva la modalità Verbose (proliso).

range delle porte da scansionare (in questo caso, sono in totale 2^{16} perché 16 bit per numerare le porte)

3 Network Mapper (vulnerability scanner)

nmap has a modular structure that is used for integrating adjunctive components. For example, it is possible to enable the execution of one or more scripts that are specifically designed for finding vulnerabilities in the software installed on the target machine. For example:

`sudo nmap -sV -sC -v <ip_host_address>`

-sV (Version Detection)

Invece di limitarsi a dire che la porta 80 è aperta, nmap prova a determinare esattamente quale software sta girando e la sua versione specifica. Perché è importante? Conoscere la versione esatta permette all'attaccante (o al difensore) di cercare vulnerabilità specifiche associate a quel rilascio.

-sC (Default Scripts)

Attiva il set di script predefiniti del "Nmap Scripting Engine" (NSE). Questi script automatizzano compiti comuni come: Recuperare informazioni più dettagliate rispetto a una scansione normale. Effettuare controlli di sicurezza rapidi.

The parameter “-sC” is used to run nmap enabling the “default” set of scripts. They are useful to collect more information than the execution without scripts. **Warning:** some of the default scripts are quite “aggressive” in their scanning activity. This means that they could create availability issues to the probed targets. Moreover, the “-sV” is used for better identification of the versions of the different services that are exposed.

Another typical example is the “vuln” script that is part of the standard nmap distribution.

→ `sudo nmap --script vuln -v <ip_host_address>`

In the previous example, the script “vuln” has been used to inspect the services running on the machine and likely some known vulnerabilities have been reported.

These vulnerabilities, that are related to the web server that is installed on the target machine, can be better investigated using a specific tool for this kind of issue. For example, the [Nikto web server scanner](#).

→ `nikto -h <ip_host_address>`

Scans the web server running on the target machine that responds at port 80 (http protocol, no security features provided by means of encryption). For an evaluation of the https version (port 443) the proper syntax is:

→ `nikto -h <ip_host_address> -ssl`

Going back to nmap and the usage of specific scripts to find vulnerabilities, another interesting ~~probe~~^{analysis} is executed by means of the following command. **Warning: it must be used only in a controlled environment.**

→ `nmap -p 22 --script ssh-brute -v <ip_host_address>`

The main addition is that now nmap implements a brute-force attack on an exposed service (i.e., secure shell, ssh). In other words, it tries a set of predefined and frequently used combinations of username and password. **More details about brute-force attacks will be introduced later in this course.**

Many useful scripts are available on the Internet to enhance the vulnerability scanning features of nmap. For example: [vulscan](#). Please, before installing and using them, consider your threat model and your trust in such tools (that it will often need to be executed with high privileges).

4A

Privilege Escalation

If in the target machine there is a user with a weak password (e.g., user="test", password="123456") then the attacker will have an entrypoint to the system. The next step for the attacker will be a lateral movement (i.e., finding other devices to be compromised) or a privilege escalation (i.e., becoming the administrator of the devices, that is the "root" user in the GNU/Linux operating system).

The local privilege escalation is typically based on wrong configurations or unpatched software vulnerabilities. A software tool designed for spotting local vulnerabilities of this kind is [Lynis](#). As shown during the lesson, it can be installed and then used without the administrator privileges and it is able to report many weak spots found in the system. Please note that a software tool like Lynis can be used for **offensive objectives** but also for **defensive purposes** (i.e., enhancing the security of our system, that is called **hardening**).

4B

Exploitation

The final phase of the procedure described in this tutorial is the exploitation of the vulnerabilities found in the target host. This part is not reported here but those who are interested in this topic can refer to the famous [Metasploit](#) penetration testing framework. In particular, the "[Metasploitable3](#)" virtual machine can be very useful to run the exploits provided by Metasploit.